Algoritmi e Protocolli per la Sicurezza

Project Work

WP3: Analisi di sicurezza

Analisi critica del protocollo di voto elettronico proposto nel WP2

Autori: Gennaro Foschillo
Francesco Vittorio Allocca

A.A. 2025–2026

Indice

1 Analisi di sicurezza **1**

1.1 Obiettivo del Work Package . . . 1
1.2 Metodo di analisi . . . 1
1.3 Assunzioni di sicurezza considerate . . . 1
1.4 Criticità considerate . . . 2
1.5 Classificazione sintetica delle proprietà . . . 3

2 Analisi per proprietà **5**

2.1 Autenticità dell'elettore e del voto . . . 5
2.2 Autorizzazione e idoneità . . . 5
2.3 Unicità del voto . . . 6
2.4 Segretezza della preferenza . . . 7
2.5 Pseudoanonimato e separazione delle informazioni . . . 7
2.6 Integrità dei messaggi e del registro . . . 7
2.7 Verificabilità individuale . . . 8
2.8 Verificabilità universale . . . 8
2.9 Disponibilità . . . 8
2.10 Resistenza al replay . . . 9
2.11 Coercizione e voto di scambio . . . 9
2.12 Efficienza . . . 10

3 Analisi rispetto agli avversari del modello **10**

3.1 Elettore malevolo . . . 10
3.2 Voting Server malevolo . . . 10
3.3 Registro Elettorale malevolo . . . 11
3.4 Government Authority malevola o compromessa . . . 11
3.5 Scrutiny Authority collusa o compromessa . . . 11
3.6 Voting Client compromesso e phishing . . . 11
3.7 Avversario di rete . . . 12

4 Analisi dei compromessi progettuali **12**

5 Verifica di possibili modifiche ovvie al WP2 **13**

6 Rischi residui **14**

7 Possibili estensioni future **15**

8 Conclusione dell'analisi **15**

1 Analisi di sicurezza

1.1 Obiettivo del Work Package

Questo Work Package analizza la sicurezza della soluzione proposta nel WP2 rispetto al modello definito nel WP1. L'obiettivo è valutare quali proprietà vengono soddisfatte e in quale misura, elencando eventuali rischi residui derivanti dal protocollo descritto nel WP2.

L'analisi considera il caso di referendum binario descritto nei WP precedenti. Le proprietà analizzate sono autenticità, autorizzazione, unicità del voto, segretezza della preferenza, pseudoanonimato, integrità, verificabilità individuale, verificabilità universale, resistenza al replay, disponibilità, coercizione ed efficienza.

1.2 Metodo di analisi

L'analisi viene svolta confrontando, per ciascuna proprietà:

- l'obiettivo dichiarato nel modello del WP1;
- i meccanismi effettivamente introdotti nel protocollo del WP2;
- le assunzioni necessarie affinché tali meccanismi siano efficaci;
- gli scenari di attacco mitigati dal protocollo;
- i limiti residui non eliminati dalla soluzione proposta.

L'analisi sottolinea le eventuali debolezze o criticità del sistema , verificando se esistono eventuali modifiche ovvie applicabili all'interno del WP2 che migliorino una proprietà senza peggiornarne altre. Quando una modifica produce benefici ma introduce costi, complessità o peggioramenti su altre proprietà, viene trattata come possibile estensione o come compromesso non adottato.

Si assume che le primitive crittografiche utilizzate siano implementate correttamente e che siano sicure rispetto ad avversari computazionalmente limitati. In particolare, l'analisi si basa su firme digitali non falsificabili, funzioni hash resistenti alle collisioni, cifratura asimmetrica probabilistica per la scheda, canali sicuri autenticati e strutture Merkle-based per la verifica di inclusione.

1.3 Assunzioni di sicurezza considerate

Assunzione	Descrizione
Primitive crittografiche sicure	Firme digitali, hash, cifratura probabilistica, MAC e canali sicuri sono considerati sicuri contro avversari efficienti. Una rottura di tali primitive invaliderebbe le garanzie associate.

Assunzione	Descrizione
Corretta gestione delle chiavi	Le chiavi private delle entità infrastrutturali e dell'elettore devono rimanere segrete. La compromissione di una chiave privata consente impersonificazione o accesso improprio alla fase corrispondente.
PKI e CRL disponibili	Certificati e liste di revoca pubblicati dalla Government Authority devono essere recuperabili, firmati e aggiornati. Le componenti devono rifiutare certificati scaduti, non coerenti con il ruolo o revocati.
Voting Client non pienamente fidato	Il client è eseguito sul dispositivo dell'elettore e può essere compromesso. Il protocollo può rilevare alcune sostituzioni tramite commitment e ricevuta, ma non può garantire pienamente che la preferenza visualizzata, quella cifrata e quella intesa dall'utente coincidano.
Separazione delle responsabilità	La sicurezza dipende dal fatto che le entità non colludano tutte tra loro. La separazione GA–VS–ER–SA riduce il rischio di associazione identità-voto, ma non elimina il rischio in caso di collusione estesa.
Scrutiny Authority distribuita	Almeno k nodi della Scrutiny Authority devono autorizzare lo scrutinio finale. Nel protocollo questa è una custodia distribuita dell'uso di sk_{SA}.
Sincronizzazione temporale ragionevole	Timestamp, finestre di validità, CRL e chiusura delle urne richiedono una sincronizzazione sufficiente tra le entità. Errori temporali possono causare rifiuti legittimi o accettazioni non desiderate.
Disponibilità minima dell'infrastruttura	La crittografia non impedisce attacchi di blocco, saturazione o indisponibilità. Si assume che GA, VS, ER, punti di pubblicazione e canali abbiano misure operative minime di disponibilità.

1.4 Criticità considerate

Prima di analizzare le singole proprietà, è utile isolare alcuni punti del protocollo che richiedono un'assunzione esplicita o che possono generare rischi residui.

Veridicità dello stato dei token spesi. Il registro $SpentTokensDB$ è interno al Voting Server. Un osservatore esterno non può sapere direttamente se il Voting Server stia dichiarando correttamente quali token siano in stato *pending* o *committed*. La verifica pubblica può controllare la coerenza tra i record pubblicati nel Bulletin Board, le ricevute firmate dal Registro Elettorale, la radice finale e il numero di schede scrutinate. Tuttavia, la correttezza completa dello stato interno del Voting Server resta un'assunzione operativa. Se il Voting Server è disonesto, può rifiutare richieste legittime, bloccare token o non inoltrare schede; tali comportamenti sono rilevabili solo in parte tramite assenza di ricevuta e incoerenze tra record attesi e record pubblicati.

Identità dell'entità nella richiesta di certificazione. La richiesta di certificazione non può basarsi solo su un'identità dichiarata dall'entità richiedente. La GA deve verificare l'identità o il ruolo dell'entità prima di emettere il certificato, e deve richiedere anche

una prova di possesso della chiave privata associata alla chiave pubblica da certificare. In caso contrario, un attaccante potrebbe chiedere un certificato per una chiave pubblica controllata da lui fingendosi Voting Server, Registro Elettorale o nodo della Scrutiny Authority. Questa criticità riguarda la fase di accreditamento e certificazione, non la cifratura del voto in sé.

Emissione concorrente dei token. Il vincolo di un solo token per la coppia ID_U, $ID_{Election}$ richiede che l'aggiornamento di $IssuedTokensDB$ sia atomico. Se due richieste parallele dello stesso elettore vengono elaborate senza blocco o transazione, la GA potrebbe emettere due token validi prima di aggiornare lo stato. Per questo, l'analisi assume che la GA registri immediatamente lo stato di emissione del token, o comunque esegua controllo e aggiornamento nella stessa operazione atomica.

Possibilità di risalire al voto di un elettore. Dal solo Bulletin Board pubblico non dovrebbe essere possibile risalire al voto di un elettore, perché i record pubblici contengono schede cifrate e non identità reali o token. Il rischio nasce dalla combinazione di più fonti: associazione identità-token nella GA, stato dei token nel VS, ordine o timestamp dei record nel Registro, log di rete e informazioni disponibili alla Scrutiny Authority durante lo scrutinio. Quindi il protocollo offre pseudoanonimato sotto separazione delle responsabilità, ma non anonimato assoluto contro collusione o compromissione estesa.

Dimostrabilità del voto da parte dell'elettore. La ricevuta del protocollo non contiene la preferenza e quindi non dovrebbe essere, da sola, una prova trasferibile del voto. Rimangono però prove esterne: screenshot, registrazioni dello schermo, osservazione fisica durante il voto, client controllato da terzi o conservazione dei dati locali usati per generare la scheda cifrata. In particolare, se il client conserva o rende esportabili i valori casuali usati nella cifratura probabilistica, l'elettore potrebbe tentare di dimostrare che una certa scheda cifrata corrisponde a una certa preferenza. La soluzione riduce le prove generate dal protocollo, ma non elimina la coercizione nel voto remoto.

1.5 Classificazione sintetica delle proprietà

La tabella seguente riassume il livello con cui il protocollo supporta le proprietà dichiarate nel modello. La classificazione distingue tra proprietà supportate direttamente, proprietà mitigate sotto assunzioni e proprietà non pienamente garantite.

Proprietà	**Livello**	**Meccanismi principali**	**Limite principale**
Autenticità	Supportata sotto assunzioni	Autenticazione GA, certificati, token firmato, binding con pk_U, firma σ_U^{Ballot}, verifica CRL	Dipende dalla correttezza della GA e dalla protezione di sk_U.
Autorizzazione	Supportata sotto assunzioni	$EligibleUsersDB$, $IssuedTokensDB$, $Permit_U$, firma σ_{GA}^{Permit}	La GA rimane una componente fidata per l'idoneità.

Proprietà	**Livello**	**Meccanismi principali**	**Limite principale**
Unicità	Supportata sotto assunzioni	Token unico, vincolo di emissione per $(ID_U, ID_{Election})$, $SpentTokensDB$, stati *pending*/*committed*	Dipende dall'atomicità dei controlli sul VS e dalla gestione delle anomalie *pending*.
Segretezza	Mitigata	Cifratura probabilistica con pk_{SA}, voto opaco per VS ed ER, scrutinio post-chiusura	Non resiste a client compromesso, uso improprio di sk_{SA} o collusione critica.
Pseudoanonimato	Mitigato	Separazione identità-token-voto, token non pubblicato, assenza della preferenza in chiaro durante raccolta e registrazione	Rimane possibile correlazione tramite log, timing, ordine dei record o collusione.
Integrità	Supportata con rilevabilità	Firme digitali, hash, commitment, Merkle Tree, ricevute firmate, $Root_{final}$	Alcune alterazioni vengono rese rilevabili, non sempre preventivamente impedite.
Verificabilità individuale	Supportata in forma limitata	$Receipt_U$, $BallotCommit_U$, $Leaf_i$, $MerklePath_i^{final}$, $Root_{final}$	Verifica l'inclusione della scheda cifrata, non prova da sola che il client abbia cifrato la preferenza voluta.
Verificabilità universale	Parziale	BB_{final}, $Root_{final}$, $TallyBoard$, firme ER/SA, controllo numerico	Non consente a un osservatore esterno di verificare autonomamente ogni decifratura.

Proprietà	Livello	Meccanismi principali	Limite principale
Disponibilità	Non garantita crittograficamente	Hard-fail CRL, canali sicuri, separazione funzionale, controlli efficienti	DoS, blocchi di rete e indisponibilità dei servizi restano rischi residui.
Efficienza	Considerata progettualmente	Referendum binario, Merkle path logaritmico, canale simmetrico di sessione, assenza di registro pubblico distribuito complesso	La misura quantitativa dei costi resta demandata al WP4.

2 Analisi per proprietà

2.1 Autenticità dell'elettore e del voto

L'autenticità dell'elettore è supportata dalla fase di autenticazione presso la Government Authority. Il modulo IP verifica l'identità reale dell'utente, mentre il modulo EV controlla la presenza dell'utente in $EligibleUsersDB$. Il token rilasciato dalla GA è firmato tramite sk_{GA}, quindi il Voting Server può verificare che l'autorizzazione provenga dall'autorità prevista.

L'autenticità della busta di voto è rafforzata dal binding tra $Permit_U$ e pk_U. Il Voting Client firma la busta tramite sk_U, e il Voting Server verifica la firma usando la chiave pubblica contenuta nel permesso firmato dalla GA. In questo modo, un avversario che ottenga solo il token, ma non sk_U, non dovrebbe poter produrre una busta valida.

Nella fase di certificazione delle entità infrastrutturali, la GA deve inoltre verificare che il richiedente sia davvero l'entità dichiarata e che possieda la chiave privata corrispondente alla chiave pubblica da certificare. Senza questa verifica iniziale, un certificato firmato dalla GA potrebbe legittimare una chiave controllata da un attaccante.

Il limite principale è che l'autenticità dipende dalla protezione della chiave privata dell'elettore e dalla correttezza della GA. Se il dispositivo dell'elettore è compromesso o se sk_U viene sottratta, l'attaccante può votare come l'utente. Se la GA è disonesta, può emettere token in modo improprio o alterare la procedura di idoneità.

2.2 Autorizzazione e idoneità

L'autorizzazione è separata dall'autenticazione. Un utente può essere autenticato correttamente, ma riceve il token solo se risulta idoneo per $ID_{Election}$. Questa distinzione è coerente con il modello del WP1, perché evita di confondere identità digitale e diritto di partecipazione alla specifica consultazione.

Il registro $IssuedTokensDB$ impedisce, sotto assunzioni di correttezza della GA, l'emissione di più token allo stesso elettore per la stessa elezione. Questa garanzia richiede che controllo ed aggiornamento dello stato siano atomici: in presenza di richieste parallele, la GA deve segnare immediatamente l'emissione o bloccare la coppia $(ID_U, ID_{Election})$ prima di restituire un nuovo token. Questa scelta tutela l'unicità già nella fase di autorizzazione, prima ancora della raccolta del voto.

Il database dei token emessi è però sensibile. Se conserva in chiaro l'associazione tra identità reale e token, una sua compromissione non rivela direttamente la preferenza, ma fornisce un elemento forte per correlazioni successive con log del VS, metadati di rete o informazioni di scrutinio. Questo richio è mitigato salvando i token cifrati precedentemente con la chiave pubblica dell'utente.

Il rischio residuo è che $IssuedTokensDB$ è un registro interno della GA. Un osservatore esterno non può verificare direttamente che la GA non abbia emesso token impropri, a meno che non siano previste procedure amministrative o verifiche esterne. Nel protocollo proposto, questa rimane una assunzione di fiducia sulla Government Authority.

2.3 Unicità del voto

L'unicità è supportata da due livelli. Il primo livello è lato GA: per ogni coppia $(ID_U, ID_{Election})$ deve essere emesso al più un token. Il secondo livello è lato VS: il token non può essere riutilizzato perché il Voting Server memorizza in $SpentTokensDB$ un digest non invertibile derivato da $SerialNumber_{Token}$ e da un sale deterministico legato a K_{Master_Server}.

La distinzione tra stato *pending* e stato *committed* è rilevante. Lo stato *pending* blocca subito riusi concorrenti del token dopo la verifica positiva del Voting Server. Lo stato *committed* viene assegnato solo dopo la ricezione di una ricevuta firmata dal Registro Elettorale. Questa scelta evita che un token venga considerato definitivamente speso prima che esista una prova firmata di presa in carico della scheda.

Un limite importante è che $SpentTokensDB$ non è pubblico. Il sistema può pubblicare conteggi, ricevute e record finali, ma un verificatore esterno non vede direttamente lo stato interno usato dal VS per decidere se un token è speso. La garanzia di unicità dipende quindi dalla correttezza del VS e dalla possibilità di rilevare anomalie tramite ricevute, audit e coerenza tra token in stato committed e schede effettivamente presenti nel Bulletin Board.

Il rischio residuo riguarda le anomalie operative. Se il Registro Elettorale non risponde, se la ricevuta non arriva o se il canale tra VS ed ER fallisce, il token può rimanere in stato *pending*. Sbloccare automaticamente il token migliorerebbe la disponibilità, ma aprirebbe il rischio di doppio voto in presenza di ritardi o risposte duplicate. Per questo motivo, nel protocollo fissato, una entry *pending* persistente deve essere trattata come anomalia, non come semplice rollback automatico.

2.4 Segretezza della preferenza

La segretezza della preferenza è supportata dalla cifratura probabilistica della scheda tramite pk_{SA}. Il Voting Server e il Registro Elettorale ricevono e pubblicano $EncVoto_{SA}$, non il voto in chiaro. L'uso di cifratura probabilistica è necessario soprattutto nel referendum binario: se la cifratura fosse deterministica, due voti uguali produrrebbero lo stesso ciphertext e un osservatore potrebbe riconoscere pattern tra schede pubblicate.

La segretezza vale però solo sotto ipotesi precise. Il Voting Client vede la preferenza prima della cifratura; quindi un client compromesso può leggerla o modificarla. La Scrutiny Authority, durante lo scrutinio, accede alle preferenze decifrate o comunque al risultato della decifratura. Se la SA conserva una mappa tra indice del record e preferenza, oppure collude con ER e VS, il rischio di ricostruzione del voto individuale aumenta.

La soluzione mitiga il problema evitando di pubblicare la corrispondenza della i-sima scheda con il voto associato, pubblicando solo il risultato aggregato.

2.5 Pseudoanonimato e separazione delle informazioni

Il protocollo separa le informazioni trattate dalle diverse entità. La GA conosce l'identità reale dell'elettore e rilascia un token, ma non riceve la scheda cifrata nella fase di voto. Il Voting Server verifica il token e la prova di possesso, ma non dovrebbe conoscere l'identità reale dell'elettore né la preferenza. Il Registro Elettorale pubblica schede cifrate e commitment, ma non token o identità. La Scrutiny Authority opera sul Bulletin Board finale, non sull'elenco degli elettori.

Questa separazione supporta lo pseudoanonimato, ma non garantisce anonimato assoluto. Un avversario che combini log di rete, timestamp, ordine dei record, informazioni del VS e informazioni della GA può tentare correlazioni. Il rischio cresce se più entità colludono o se i log operativi sono troppo dettagliati.

In questa sezione è quindi corretto parlare di pseudoanonimato mitigato, non di anonimato forte. Il rischio residuo di correlazione viene quindi accettato come conseguenza del protocollo scelto e del vincolo di efficienza.

2.6 Integrità dei messaggi e del registro

L'integrità dei messaggi è supportata da firme digitali, certificati, MAC del canale sicuro e controlli di freschezza. La sola cifratura non viene considerata sufficiente a garantire integrità; per questo il protocollo usa firme sugli oggetti persistenti e canali autenticati per gli scambi di sessione.

Il Registro Elettorale fornisce integrità e rilevabilità delle manomissioni tramite struttura append-only e Merkle Tree. Ogni record produce una foglia $Leaf_i$, e la radice finale $Root_{final}$ viene firmata dal Registro. Una modifica a un record pubblicato altererebbe la foglia e quindi la radice finale, rendendo rilevabile la manipolazione.

Il commitment $BallotCommit_U$ consente all'elettore di rilevare una sostituzione della scheda cifrata rispetto a quella prodotta localmente. Tuttavia, il commitment non impedisce a un Voting Server malevolo di costruire una nuova coppia coerente

$(EncVoto'_{SA}, BallotCommit'_U)$. La protezione in questo caso è di rilevabilità: l'elettore può accorgersi della sostituzione confrontando il commitment ricevuto con quello conservato localmente.

2.7 Verificabilità individuale

La verificabilità individuale permette all'elettore di controllare che la propria scheda cifrata sia stata inclusa nel Bulletin Board finale. L'elettore verifica la firma del Registro sulla ricevuta, la presenza della foglia nella struttura pubblicata, il Merkle path definitivo e la firma sulla radice finale. Verifica inoltre che $BallotCommit_U$ nella ricevuta e nel record coincida con il valore calcolato localmente.

Questa proprietà permette all'elettore di controllare che la scheda cifrata registrata sia quella associata al commitment prodotto dal client. Non dimostra però, da sola, che la preferenza cifrata corrisponda alla scelta che l'elettore intendeva esprimere. Se il client mostra "Sì" ma cifra "No", il protocollo base non fornisce una prova indipendente capace di rilevare sempre l'errore.

La ricevuta non contiene la preferenza in chiaro e non include una prova pubblica dell'opzione votata. Questo riduce il rischio che venga usata come prova trasferibile in scenari di coercizione o compravendita del voto.

2.8 Verificabilità universale

La verificabilità universale del protocollo è una verificabilità pubblica di coerenza. Un osservatore può controllare che i record del Bulletin Board siano coerenti con $Root_{final}$, che la radice sia firmata dal Registro Elettorale, che il numero di record coincida con $N_{committed}$, che vi siano almeno k autorizzazioni valide della Scrutiny Authority e che il risultato aggregato rispetti la relazione:

$$m = count_{\text{Sì}} + count_{\text{No}} + count_{invalid}.$$

Questa verifica è utile perché collega il risultato all'insieme cristallizzato dei record pubblicati. Tuttavia, non permette a chiunque di verificare autonomamente che ogni ciphertext sia stato decifrato correttamente e conteggiato nel modo giusto. Mancano infatti prove pubbliche di corretta decifratura per ogni singola scheda. Questa scelta mantiene il protocollo più semplice, ma limita la verificabilità universale.

Per questo motivo, nel documento la verificabilità universale è dichiarata come proprietà rispettata parzialmente. Il sistema offre trasparenza pubblica su record, firme, radice Merkle, autorizzazioni e coerenza numerica, ma la correttezza interna della decifratura rimane affidata alla procedura congiunta della Scrutiny Authority.

2.9 Disponibilità

La disponibilità non è garantita direttamente dalle primitive crittografiche. Un avversario può bloccare il Voting Client, saturare il Voting Server, rendere irraggiungibile il punto

di pubblicazione della CRL, ritardare la risposta del Registro Elettorale o impedire la cooperazione di almeno k nodi della Scrutiny Authority.

Il protocollo contiene alcune scelte che riducono il carico e quindi aiutano indirettamente la disponibilità. Il Voting Server esegue prima controlli economici e solo dopo verifiche crittografiche più costose. Le entità possono mantenere in cache oggetti firmati come $Params_{Election}$ e $CRL_{Election}$, controllandone versione e validità. La verifica Merkle ha costo logaritmico per l'elettore.

Rimane però un compromesso: il comportamento hard-fail sulla CRL migliora la sicurezza contro certificati revocati, ma peggiora la disponibilità quando la CRL non è recuperabile o verificabile. Questa scelta è dichiarata come trade-off consapevole.

2.10 Resistenza al replay

Il protocollo mitiga i replay tramite nonce, timestamp, finestre temporali e stato dei token. Un token già usato produce lo stesso riferimento in $SpentTokensDB$ e viene rifiutato se risulta in stato *pending* o *committed*. La busta di voto contiene $nonce_{ballot}$, e il canale sicuro richiede freschezza della sessione.

Il rischio residuo non è tanto la riaccettazione dello stesso token, quanto la gestione di replay o ritardi in condizioni di rete anomale. Ad esempio, se un messaggio viene ritardato mentre il token è in stato *pending*, il sistema può produrre una situazione di blocco operativo. Questa è una criticità di robustezza e disponibilità, non una rottura diretta dell'unicità.

2.11 Coercizione e voto di scambio

Il protocollo non elimina totalmente la coercizione. Il voto avviene in un ambiente remoto non presidiato, quindi un coercitore può osservare fisicamente l'elettore, imporre l'uso di un client controllato o richiedere prove esterne come registrazioni e screenshot.

La ricevuta del protocollo non contiene la preferenza e non pubblica la corrispondenza tra record e voto decifrato. Questa scelta riduce la produzione di prove trasferibili generate direttamente dal sistema. Tuttavia, non impedisce prove esterne prodotte dall'utente o dal dispositivo. In particolare, screenshot, registrazioni dello schermo, osservazione fisica, malware sul client o conservazione della casualità usata nella cifratura possono permettere all'elettore di dimostrare il voto a un terzo. Per questo la soluzione non deve essere presentata come resistente alla coercizione in senso forte.

L'assenza di sostituzione del voto semplifica unicità e scrutinio, ma rende il sistema meno resistente alla coercizione rispetto a modelli che consentono di votare di nuovo e considerare valido solo l'ultimo voto. Tale meccanismo non è stato adottato perché avrebbe aumentato complessità, gestione dello stato, rischio di contestazioni e carico sul protocollo.

2.12 Efficienza

L'efficienza è considerata come vincolo progettuale già nel modello e nella soluzione. Le scelte principali sono:

- referendum binario, che semplifica formato della scheda e scrutinio;
- uso della crittografia asimmetrica solo per chiavi, firme, token e cifratura della preferenza;
- uso di chiave di sessione simmetrica per proteggere i messaggi successivi al canale sicuro;
- Merkle Tree per prove di inclusione di dimensione logaritmica;
- assenza di un registro pubblico distribuito complesso e di protocolli di decifratura più avanzati come meccanismi principali;
- controlli del Voting Server ordinati dal meno costoso al più costoso;
- pubblicazione aggregata del risultato, evitando di pubblicare grandi prove crittografiche non previste dal protocollo base.

Queste scelte rendono il protocollo più adatto a un prototipo simulato e coerente con gli strumenti del corso. La valutazione quantitativa di tempi, dimensioni dei messaggi e costi computazionali deve essere svolta nel WP4.

3 Analisi rispetto agli avversari del modello

3.1 Elettore malevolo

Un elettore malevolo può tentare di votare più volte, riutilizzare il token, inviare schede malformate, ripudiare il voto o produrre prove da mostrare a terzi. Il riuso del token viene mitigato da $SpentTokensDB$, mentre le schede malformate possono essere scartate in fase di verifica o marcate come invalide in fase di scrutinio.

Un elettore autorizzato può comunque consumare il proprio token con una scheda non valida. Questo non altera voti altrui, ma può aumentare $count_{invalid}$. Il protocollo non impedisce a un elettore di produrre prove esterne del proprio voto tramite strumenti fuori dal protocollo.

3.2 Voting Server malevolo

Un Voting Server malevolo può tentare di accettare token non validi, riutilizzare token, sopprimere schede valide, sostituire schede cifrate o non inoltrare correttamente i record al Registro Elettorale. Le firme sui token e la verifica di σ_U^{Ballot} mitigano l'accettazione di schede non autorizzate. $SpentTokensDB$ mitiga il riuso del token. Il commitment e la ricevuta del Registro rendono rilevabile dall'elettore una sostituzione della scheda.

Il protocollo non impedisce completamente la soppressione di una scheda prima della registrazione. Se il Voting Server rifiuta o scarta una busta valida, l'elettore può accorgersi

dell'assenza di ricevuta, ma il sistema non garantisce da solo la consegna forzata al Registro. Questo è un rischio residuo di disponibilità e correttezza operativa.

3.3 Registro Elettorale malevolo

Un Registro Elettorale malevolo può tentare di non pubblicare un record, alterare record già pubblicati, produrre ricevute scorrette o pubblicare una radice finale non coerente. La firma dei record, il Merkle Tree, la ricevuta firmata e la pubblicazione di $Root_{final}$ rendono rilevabili molte manipolazioni.

Se il Registro non inserisce una scheda, l'elettore non ottiene una ricevuta valida o non riesce a trovare la propria foglia nella struttura finale. Se altera un record dopo la pubblicazione, la prova Merkle o la radice finale non risultano coerenti.

Rimane il rischio di collusione tra Registro e Voting Server. Se entrambi coordinano rifiuti o omissioni prima della produzione di ricevute, la crittografia rende più facile rilevare anomalie, ma non garantisce piena disponibilità del voto.

3.4 Government Authority malevola o compromessa

La Government Authority è una componente fortemente fidata. Può emettere certificati, revocare entità, pubblicare parametri elettorali, autenticare utenti e rilasciare token. Una GA malevola potrebbe emettere token non autorizzati, negare token a elettori legittimi, pubblicare parametri scorretti o certificare entità non affidabili.

Le firme della GA garantiscono autenticità degli oggetti pubblicati, ma non garantiscono che la GA abbia operato correttamente dal punto di vista amministrativo. Per mitigare questo rischio servirebbero audit, procedure organizzative, pubblicazione controllata degli elenchi o separazione amministrativa ulteriore. Nel protocollo base, questa è una fiducia residua dichiarata.

3.5 Scrutiny Authority collusa o compromessa

La Scrutiny Authority è distribuita per ridurre il singolo punto di fiducia. Almeno k nodi devono autorizzare lo scrutinio. Le autorizzazioni firmate rendono tracciabile la partecipazione dei nodi alla fase finale.

Il limite è che la soluzione non implementa decifratura distribuita matematica con prove pubbliche di corretta decifratura. Se almeno k nodi colludono o se sk_{SA} viene usata impropriamente, la segretezza delle schede può essere compromessa. Inoltre, la correttezza della decifratura resta affidata alla procedura congiunta e alle firme pubblicate, non a una prova verificabile da chiunque.

3.6 Voting Client compromesso e phishing

Il Voting Client compromesso è uno degli avversari più rilevanti. Può mostrare opzioni corrette ma cifrare una preferenza diversa, conservare la preferenza, inviare metadati a terzi, rubare sk_U, alterare il contenuto della busta di voto o impedire all'utente di

completare la verifica finale.

Un caso particolare è il phishing. Un attaccante può tentare di indurre l'elettore a usare un'applicazione falsa, una pagina web contraffatta o un link malevolo che imita il Voting Client ufficiale. Il rischio è maggiore perché l'attacco non richiede necessariamente di rompere le primitive crittografiche: è sufficiente convincere l'elettore a interagire con un client non autentico.

Nel protocollo questo rischio è mitigato assumendo che il Voting Client venga ottenuto esclusivamente da una fonte ufficiale e verificabile. In particolare, il client deve essere distribuito tramite un canale riconosciuto dall'autorità elettorale e deve essere firmato o comunque autenticabile rispetto alla Government Authority. L'elettore non dovrebbe usare link ricevuti tramite canali non affidabili, mentre il client ufficiale deve verificare $Params_{Election}$, i certificati delle entità coinvolte, la $CRL_{Election}$ e l'autenticità del Voting Server prima dell'invio della scheda.

Queste misure riducono il rischio di phishing e di sostituzione del client, ma non lo eliminano completamente. Se l'elettore installa volontariamente un'applicazione falsa, accede a una pagina contraffatta o utilizza un dispositivo già compromesso, il protocollo non può garantire che la preferenza visualizzata, quella cifrata e quella effettivamente inviata coincidano. Il rischio residuo deve quindi essere dichiarato chiaramente: la sicurezza del voto remoto dipende anche dalla capacità dell'utente di usare il client ufficiale e dall'integrità del dispositivo su cui il client viene eseguito.

3.7 Avversario di rete

Un avversario di rete può intercettare, modificare, ritardare o ripetere messaggi. Il canale sicuro autenticato, il key exchange autenticato, i MAC, le firme, i nonce e i timestamp mitigano eavesdropping, manomissione e replay.

Rimangono possibili attacchi di disponibilità. Un avversario può bloccare il traffico, impedire il pull di $Params_{Election}$ o $CRL_{Election}$, saturare il Voting Server o ritardare la consegna della ricevuta. La crittografia rileva o impedisce molte alterazioni, ma non garantisce consegna dei messaggi.

4 Analisi dei compromessi progettuali

Il protocollo adotta compromessi espliciti. Tali compromessi non rappresentano errori, ma scelte motivate rispetto agli obiettivi della traccia, agli strumenti trattati nel corso e al vincolo di efficienza.

Scelta	**Motivazione**	**Rischio residuo**
Referendum binario	Riduce complessità della scheda e dello scrutinio.	Minore generalità rispetto a elezioni con preferenze multiple o liste complesse.

Scelta	Motivazione	Rischio residuo
Nessuna sostituzione del voto	Mantiene semplice l'unicità del token e riduce ambiguità nello scrutinio.	L'elettore non può correggere un voto inviato e la resistenza alla coercizione è più debole.
Token non pubblicato sul Bulletin Board	Riduce la correlazione tra autorizzazione e scheda registrata.	La verifica pubblica dell'emissione corretta dei token resta limitata.
Pubblicazione del solo tally aggregato	Riduce il rischio di collegare record e preferenza decifrata.	Un osservatore esterno non verifica ogni decifratura individuale.
Custodia distribuita di sk_{SA}	Evita primitive avanzate non necessarie come soluzione principale.	Non offre una prova pubblica della corretta decifratura di ogni scheda.
Nessun registro distribuito complesso	Evita latenza, costi e complessità non proporzionati al progetto.	La trasparenza dipende dal Bulletin Board, dalle firme e dalla disponibilità dei dati pubblicati.
Nessun riordinamento crittografico delle schede	Mantiene il protocollo più semplice e più efficiente.	Resta rischio di correlazione tramite timing, ordine e metadati.
Hard-fail sulla CRL	Evita di accettare certificati revocati o stato di fiducia obsoleto.	Può interrompere operazioni legittime se la CRL non è raggiungibile.

5 Verifica di possibili modifiche ovvie al WP2

La traccia richiede di verificare se esistano modifiche immediate in grado di migliorare il protocollo senza peggiorare altre proprietà. Nel caso del WP2, le modifiche veramente compatibili con la soluzione proposta riguardano soprattutto chiarimenti operativi e controlli già coerenti con le primitive del corso.

Modifica o chiarimento	Beneficio	Limite o costo introdotto
Aggiornamento atomico di $IssuedTokensDB$	Evita doppia emissione di token in caso di richieste parallele dello stesso elettore.	Richiede gestione transazionale o lock applicativo nella GA.
Prova di possesso della chiave privata nella certificazione	Riduce il rischio che un attaccante faccia certificare una chiave non appartenente all'entità dichiarata.	Richiede un passaggio di challenge–response nella fase di accreditamento.

Modifica o chiarimento	**Beneficio**	**Limite o costo introdotto**
Pubblicazione firmata di conteggi aggregati del VS	Aiuta a confrontare token in stato *committed*, record del Bulletin Board e schede scrutinate.	Non rende pubblico $SpentTokensDB$ e quindi non elimina la fiducia residua nel VS.
Riduzione dei dati conservati in $IssuedTokensDB$	Limita l'impatto della compromissione del database dei token emessi.	La GA deve comunque conservare abbastanza stato per impedire emissioni duplicate e gestire contestazioni.
Gestione esplicita della casualità della cifratura	Riduce il rischio che l'elettore possa usare valori locali per dimostrare il voto.	Non elimina screenshot, osservazione fisica o client compromesso.
Frammentazione o custodia distribuita più rigorosa di sk_{SA}	Riduce il rischio che una singola entità possa usare la chiave di scrutinio.	Aumenta complessità operativa e richiede procedure di ricostruzione o autorizzazione più controllate.

Queste modifiche sono coerenti con il protocollo e con gli argomenti trattati, ma non sono tutte gratuite. Alcune aumentano la robustezza operativa, altre riducono il rischio di correlazione o di abuso delle chiavi, ma introducono complessità gestionale. Non emerge quindi una modifica semplice che migliori tutte le proprietà contemporaneamente senza alcun costo.

6 Rischi residui

I principali rischi residui sono i seguenti:

- compromissione del Voting Client o del dispositivo dell'elettore;
- furto o uso improprio di sk_U, con conseguente voto non autorizzato dal punto di vista dell'utente;
- collusione tra più entità infrastrutturali, in particolare tra GA, VS, ER e SA;
- uso improprio o compromissione della chiave privata di scrutinio sk_{SA};
- correlazione tramite log temporali, indirizzi di rete, ordine dei record o timestamp;
- soppressione di schede prima della produzione della ricevuta firmata;
- stati *pending* persistenti in $SpentTokensDB$, con blocco operativo del token;
- attacchi alla disponibilità di GA, VS, ER, CRL o canali di comunicazione;
- CRL non raggiungibile o non aggiornata, con conseguente hard-fail;
- assenza di piena resistenza alla coercizione nel voto remoto non presidiato;
- verificabilità universale limitata alla coerenza pubblica, senza prova autonoma di ogni decifratura.

Questi rischi non annullano l'utilità del protocollo, ma definiscono il perimetro reale delle garanzie offerte. La soluzione è difendibile se presentata come compromesso ragionevole e non come sistema di voto elettronico perfetto.

7 Possibili estensioni future

Le estensioni future vengono limitate a meccanismi coerenti con la teoria discussa nel corso e con il protocollo già definito nel WP2.

- **Rafforzamento della certificazione**: la fase di emissione dei certificati potrebbe includere in modo più esplicito challenge–response, prova di possesso della chiave privata e controlli più stringenti sul ruolo dell'entità richiedente.
- **Log firmati e audit**: GA, VS ed ER potrebbero produrre log firmati degli eventi critici, senza pubblicare dati sensibili, per rendere più controllabili emissione dei token, stati *pending*/*committed* e pubblicazione dei record.
- **Frammentazione della chiave di scrutinio**: la protezione di sk_{SA} potrebbe essere rafforzata dividendo la custodia della chiave tra più nodi, così da evitare che un singolo soggetto possa usarla autonomamente prima della chiusura delle urne.
- **Procedure più rigorose per i token in stato *pending***: si potrebbero definire timeout, contestazioni e controlli manuali firmati per evitare sia il blocco permanente del token sia il rischio di doppio utilizzo.

Queste estensioni non modificano la natura del protocollo. Servono soprattutto a ridurre rischi operativi già individuati nell'analisi, senza trasformare la soluzione in un sistema basato su primitive avanzate non necessarie per il progetto base.

8 Conclusione dell'analisi

Il protocollo proposto nel WP2 realizza un compromesso ragionevole tra sicurezza, trasparenza ed efficienza per un referendum binario. Le proprietà meglio supportate sono autenticità, autorizzazione, unicità sotto assunzioni, integrità dei record e verificabilità individuale dell'inclusione. La segretezza e lo pseudoanonimato sono mitigati dalla cifratura e dalla separazione delle responsabilità, ma non sono assoluti. La verificabilità universale è presente come controllo pubblico di coerenza tra Bulletin Board, radice Merkle, autorizzazioni di scrutinio e risultato aggregato, ma non come verifica crittografica completa di ogni decifratura.

La principale forza della soluzione è l'uso combinato di strumenti coerenti con il corso: autenticazione, PKI, firme digitali, funzioni hash, canali sicuri, nonce, timestamp e Merkle Tree. La principale debolezza è che alcune garanzie dipendono ancora dalla correttezza operativa e dalla non collusione delle entità infrastrutturali.

Nel complesso, la soluzione non pretende di eliminare tutti i rischi del voto elettronico remoto. Essa fornisce invece un modello implementabile e analizzabile, in cui i compromessi sono esplicitati e i limiti residui sono dichiarati in modo coerente con la traccia.